Flag 7 of 18: Phishing Domain

OAuth Heist scenario · Cymbal Investments · Google SecOps SIEM

Question

What is the phishing domain where employee credentials were submitted via an HTTP POST request?

Answer

sso-cymbal-portal.com

Evidence

- Zscaler web proxy event (`ZSCALER_WEBPROXY`), Cymbal namespace, method `POST` .
- User `elena.rostova` , source IP `10.240.12.65` . The popup also listed `149.50.97.174` for the destination.
- Login page: `https://sso-cymbal-portal.com/auth/login?user=elena.rostova` , with the victim username pre-filled.
- Credential submission: `https://sso-cymbal-portal.com/api/v1/auth/token` (2400 bytes sent, 800 received).
- The domain imitates the company SSO portal, which fits the ShinyHunters bulletin about phishing kits that impersonate identity providers.

How it was found

```
metadata.event_type = "NETWORK_HTTP"
AND network.http.method = "POST"
AND principal.namespace = "Cymbal"
```

Then a URL filter for login, SSO and auth keywords. Window: Oct 15 to Oct 19, 2026.

Wrong turns

- Two Demoverse lookalikes, `signin.office365x24.com` and `signin.accounts-gooqle.com` , also received POSTs to `/login.php` . They were replayed noise, not Cymbal traffic.

- The first query excluded hostnames containing `cymbal`, which removed the real answer. Attackers build lookalikes from the target name.

Lesson

Filter on the Cymbal namespace first, and do not exclude your own organization name when hunting phishing domains.

Next pivot

Search elena.rostova for MFA changes, OAuth authorization and mailbox activity after the submission.